

Segurança em Computação Validação Contínua, Purple Team e Resposta Orientada por Evidências

Prof. Jean Everson Martina

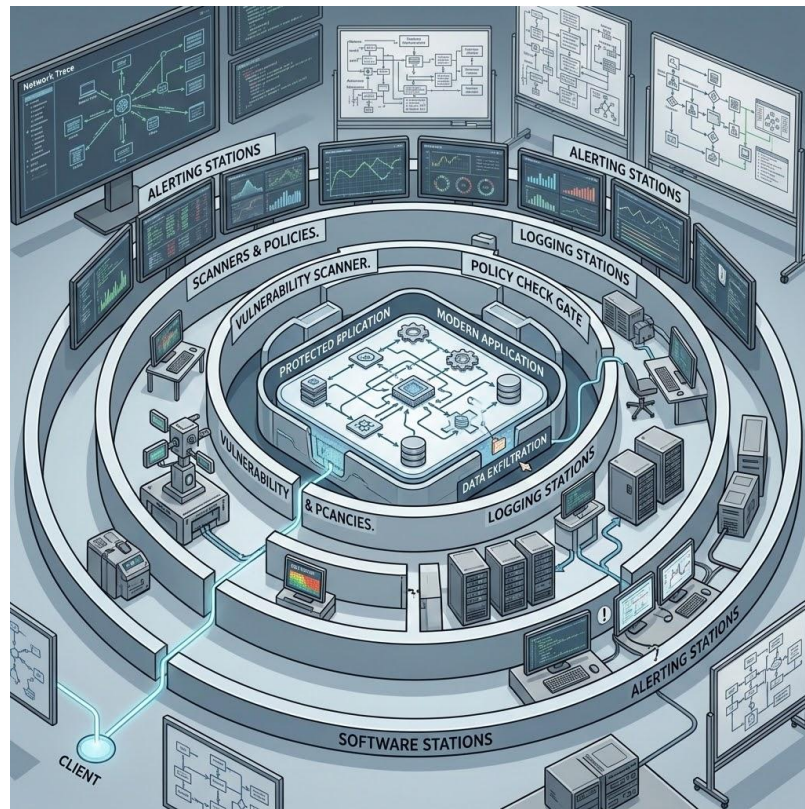
Da engenharia segura à validação contínua



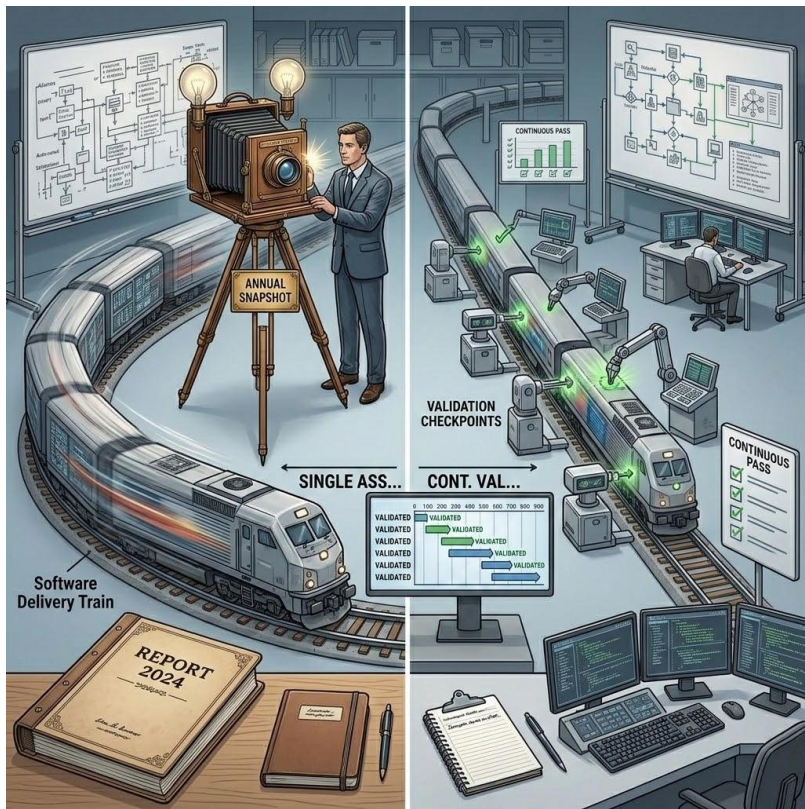
- Aula 1: segurança como processo contínuo em aplicações modernas.
- Aula 2: vulnerabilidades modernas em web, APIs e mobile.
- Aula 3: pipeline seguro com SAST, DAST, IAST, SCA e secrets.
- Aula 4: supply chain, SBOM, Infrastructure as Code e Policy as Code.
- Aula 5: validar se defesas, detecção e resposta realmente funcionam.
- Segurança não é o que o diagrama diz; é o que resiste quando alguém testa.

Prevenção não basta

- Scanners podem falhar, gerar ruído ou deixar passar vulnerabilidades reais.
- Políticas podem estar incompletas, mal calibradas ou desconectadas do risco real.
- Logs podem existir, mas não registrar o evento necessário para investigação.
- Alertas podem não disparar, disparar tarde ou gerar excesso de ruído.
- Ataques reais normalmente combinam várias falhas pequenas em um caminho explorável.
- Deploy aprovado não é certificado de segurança.



Do pentest anual à validação contínua



- Pentests tradicionais são avaliações pontuais em um sistema que continua mudando.
- Aplicações modernas mudam com CI/CD, cloud, dependências, configurações e automação.
- Validação contínua usa exercícios menores, frequentes e controlados para reduzir surpresa.
- O objetivo não é substituir pentest, mas complementar com evidência recorrente.
- Cada achado deve voltar para backlog, testes, logs, alertas, políticas e pipeline.
- Pentest anual em sistema com deploy contínuo é fotografia de carro em movimento.

Red Team, Blue Team e Purple Team

- Red Team simula caminhos de ataque e comportamento adversário realista.
- Blue Team detecta, responde, investiga e fortalece defesas.
- Purple Team aproxima ataque e defesa para melhorar evidências e controles.
- O objetivo não é “ganhar” do outro time, mas aprender com a validação.
- Exercícios bons produzem novos testes, melhores alertas, logs úteis e correções rastreáveis.
- Red Team sem Blue Team vira teatro; Blue Team sem validação vira esperança.



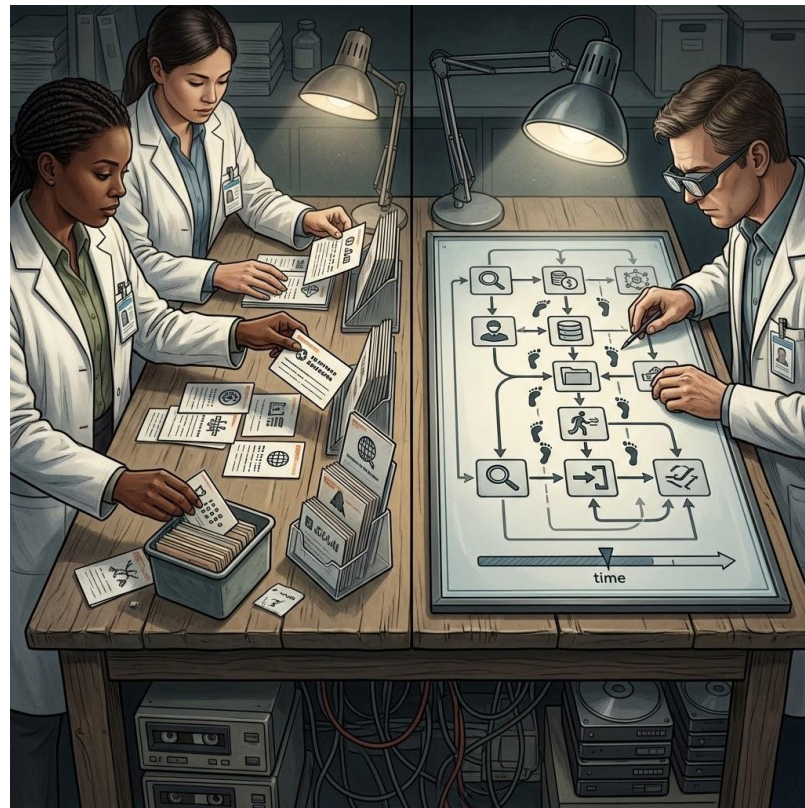
MITRE ATT&CK como linguagem comum



- MITRE ATT&CK organiza táticas, técnicas e procedimentos adversários observados no mundo real.
- Tática indica o objetivo do atacante, como obter acesso inicial ou escalar privilégios.
- Técnica indica o método usado para alcançar uma tática.
- Procedimento descreve uma execução concreta da técnica em um contexto específico.
- ATT&CK ajuda a mapear ataque, detecção, resposta, cobertura defensiva e lacunas.
- Ataque e defesa precisam falar a mesma língua.

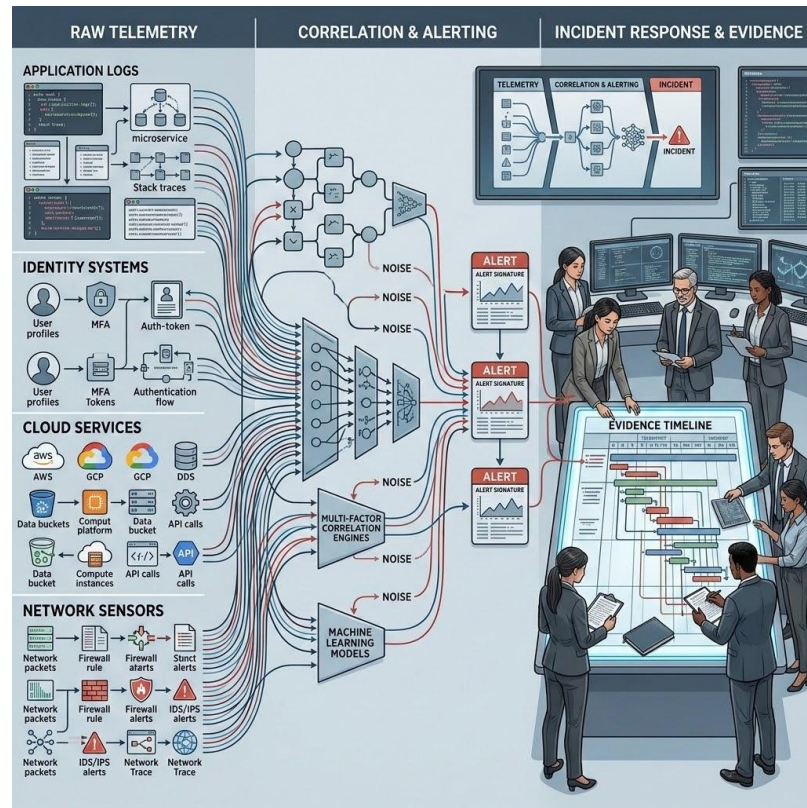
TTPs: comportamento é mais estável que indicador

- IOC é um indicador específico, como IP, domínio, hash, arquivo ou endereço.
- TTP significa táticas, técnicas e procedimentos usados por adversários.
- Indicadores mudam rapidamente e podem ser substituídos com baixo custo.
- Comportamentos ofensivos tendem a ser mais estáveis e mais difíceis de esconder.
- Detecção madura foca em padrões de comportamento, não apenas em listas de indicadores.
- IP muda, hash muda; comportamento é mais difícil de esconder.

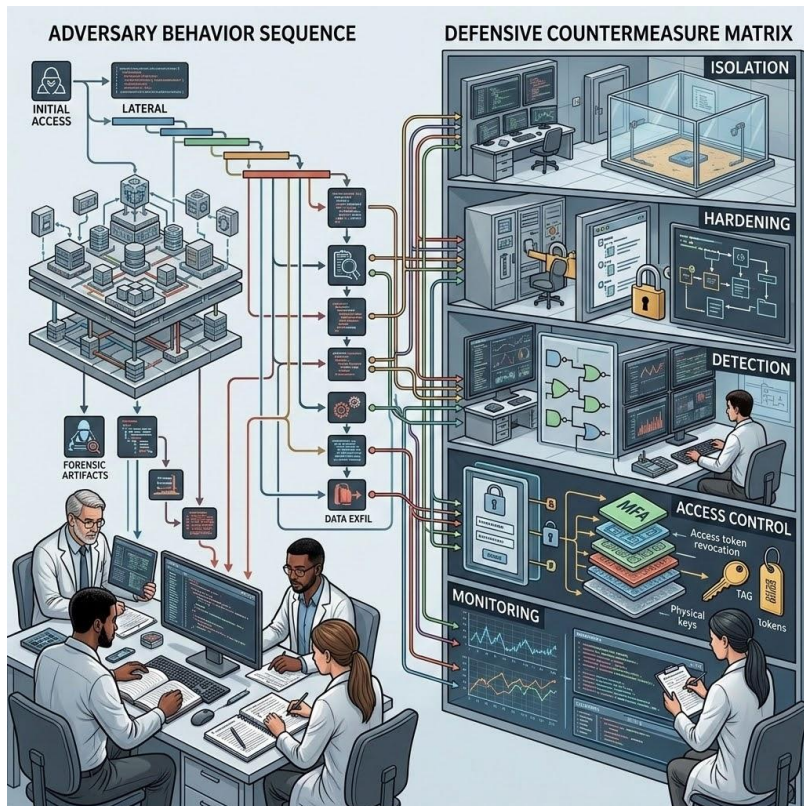


Detecção: do evento ao incidente

- Evento: algo aconteceu no sistema, na aplicação, na identidade, na rede ou na cloud.
- Alerta: um evento ou correlação parece relevante para segurança.
- Incidente: situação confirmada ou provável que exige resposta coordenada.
- Telemetria precisa vir de aplicação, infraestrutura, identidade, rede, pipeline e cloud.
- SIEM ajuda a correlacionar eventos, mas depende de logs úteis e contexto.
- Log sem contexto é diário; alerta sem ação é barulho.



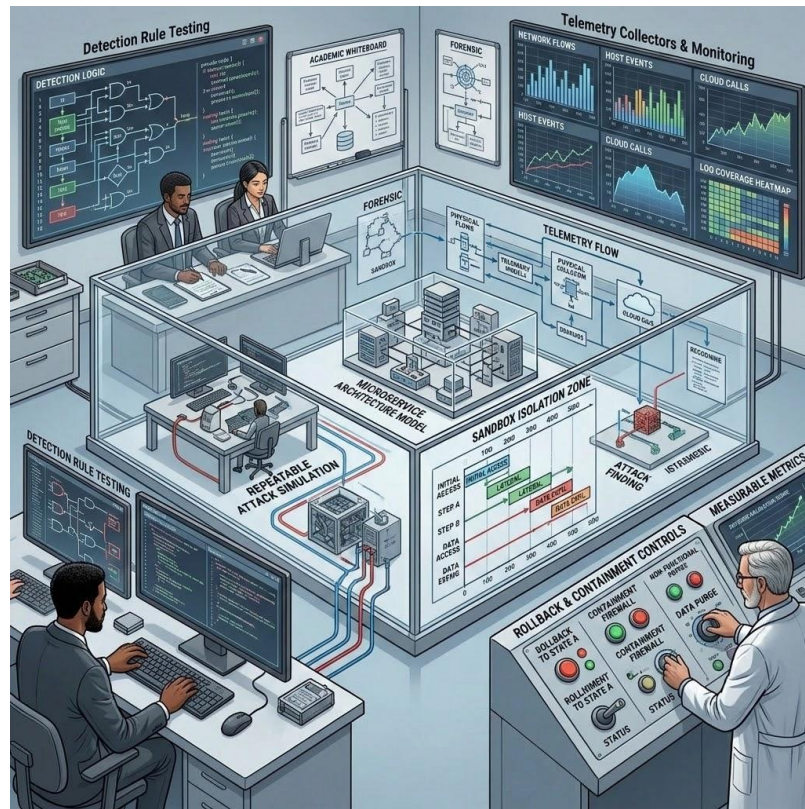
D3FEND: conectando ataque e defesa



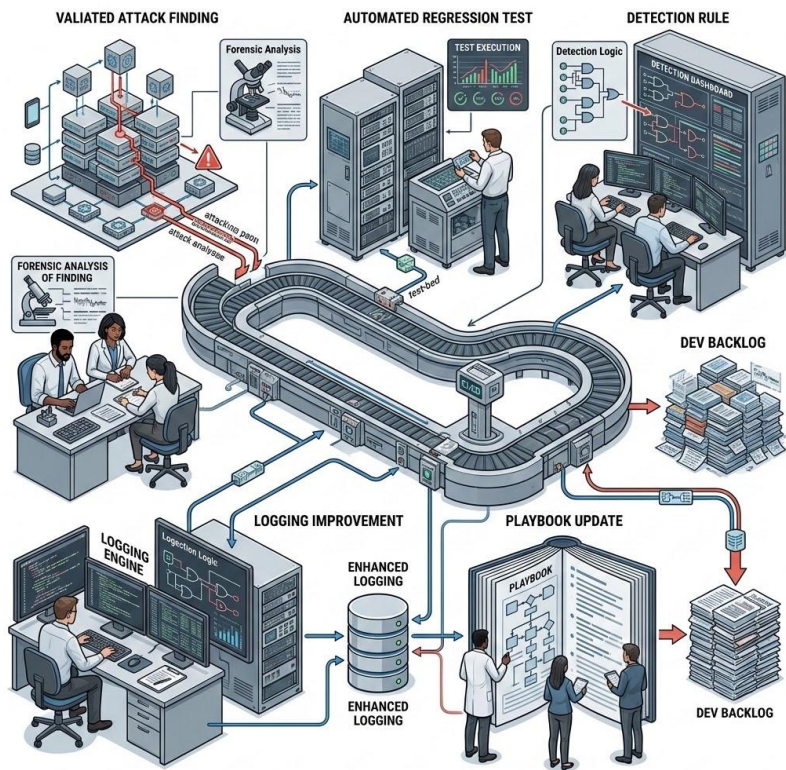
- ATT&CK ajuda a descrever como adversários atacam.
- D3FEND ajuda a organizar técnicas defensivas e contramedidas.
- Controles defensivos podem ser associados a comportamentos adversários específicos.
- Isso ajuda a discutir cobertura, lacunas e justificativa dos controles.
- D3FEND complementa ATT&CK ao estruturar o lado defensivo da conversa.
- ATT&CK pergunta como atacam; D3FEND ajuda a perguntar como defender.

Ferramentas para validação controlada

- Atomic Red Team executa testes pequenos e reproduzíveis mapeados ao MITRE ATT&CK.
- Caldera permite emulação adversarial automatizada e exercícios controlados.
- Sigma define regras de detecção portáveis entre diferentes plataformas.
- Wazuh e Elastic são exemplos de SIEM e monitoramento para coletar e correlacionar eventos.
- O foco não é atacar produção; é validar controles em ambiente seguro e autorizado.
- Validação ofensiva boa é controlada, mensurável e reversível.



Purple Team no pipeline



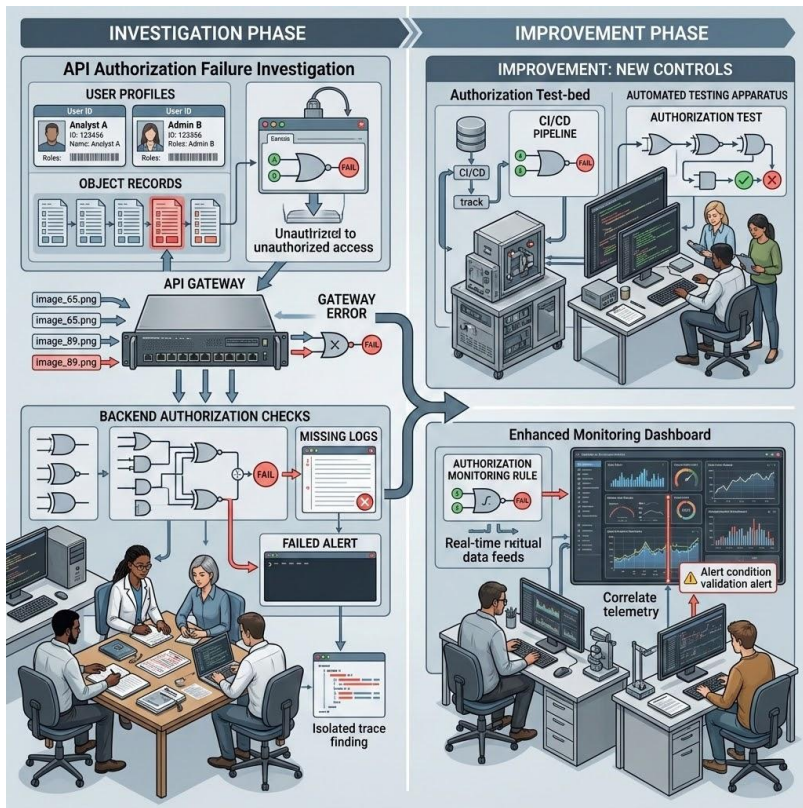
- Falha explorada deve virar novo teste automatizado.
- Incidente deve virar nova regra de detecção, novo playbook ou nova política.
- Alerta ruim deve virar melhoria de telemetria, contexto ou priorização.
- Técnica ofensiva validada deve virar caso de regressão de segurança.
- O pipeline passa a incorporar aprendizado defensivo de forma contínua.
- Toda falha explorada deveria deixar uma cicatriz no pipeline.

Resposta a incidentes no ciclo moderno

- Preparação define papéis, contatos, acessos, ferramentas, logs e playbooks.
- Detecção e análise confirmam o que aconteceu, onde ocorreu e qual é o impacto.
- Contenção reduz dano e impede avanço do atacante.
- Erradicação remove causa, credenciais comprometidas, persistência e artefatos maliciosos.
- Recuperação restaura operação com segurança e validação.
- Lições aprendidas devem voltar para backlog, pipeline, políticas e treinamento.



Exemplo integrado: falha em API



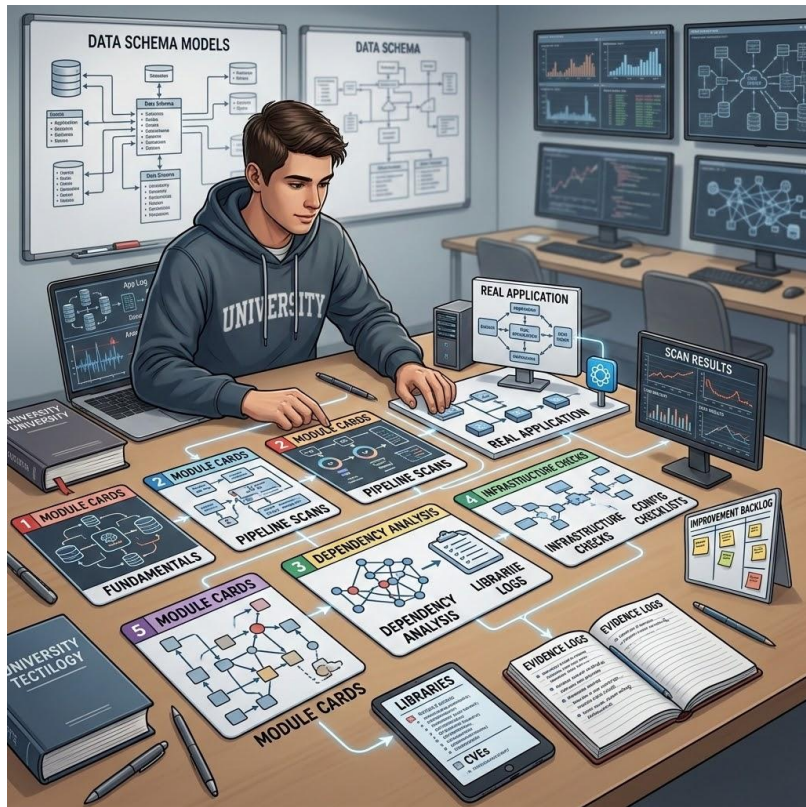
- API com BOLA permite acesso indevido a objetos de outro usuário.
- Pipeline não tinha teste automatizado de autorização por objeto.
- DAST não cobriu fluxo autenticado com múltiplos usuários.
- Log registrava acesso ao endpoint, mas não o objeto acessado.
- Alerta não disparou porque não havia regra de comportamento anômalo.
- Purple Team reproduz o acesso e transforma a falha em teste, log, alerta e backlog.

Métricas que importam

- Tempo para detectar e tempo para conter indicam maturidade de resposta.
- Cobertura de logs mostra se existe evidência suficiente para investigar.
- Cobertura de técnicas ATT&CK ajuda a entender lacunas defensivas.
- Vulnerabilidades recorrentes indicam falhas de processo, não apenas erros individuais.
- Alertas úteis versus ruído indicam qualidade da detecção.
- O que não é medido vira sensação; sensação em segurança é uma péssima métrica.



Trabalho prático: conectando as cinco aulas



- O trabalho materializa o ciclo DevSecOps em um sistema próprio.
- Aula 1: entender a aplicação moderna e sua superfície de ataque.
- Aula 2: reconhecer vulnerabilidades e classes de falhas.
- Aula 3: implementar validações no pipeline.
- Aula 4: analisar dependências, infraestrutura e configuração.
- Aula 5: interpretar evidências, priorizar riscos e propor melhoria contínua.
- O objetivo não é rodar ferramenta; é transformar achados em análise técnica e decisão de engenharia.

Fechamento do bloco: segurança como ciclo

- Aplicações modernas ampliam a superfície de ataque.
- Vulnerabilidades são falhas de engenharia, integração e operação.
- Pipeline transforma segurança em validação contínua.
- Supply chain e IaC exigem visibilidade, rastreabilidade e controle.
- Purple Team e resposta validam se a defesa realmente funciona.
- Segurança moderna é construir, validar, observar, responder e melhorar. Sem parar.

